# SAST and SCA: results and remediation

English version of ../../security/SAST-SCA.md. The report records the static security (SAST) and dependency (SCA) review. The run was made as part of the LCT checklist (block 3.2) and is repeated in CI on every push (the `security` job in `.github/workflows/ci.yml`).

Run date: 23.09.2026.

## 1. SAST — Bandit

```
python -m bandit -c pyproject.toml -r backend/ -f txt
```

| Metric | Value |
|---|---|
| Lines scanned | 5 229 |
| High | 0 |
| Medium | 0 |
| Low | 0 |

### What was found and how it was fixed

| Rule | Location | Assessment | Resolution |
|---|---|---|---|
| B110 (try/except/pass) | `backend/main.py`, `backend/middleware/audit.py` | Not a real issue: suppression of expected errors | Replaced with an explicit `contextlib.suppress(...)` and an explaining comment |
| B101 (assert) | `backend/services/guide_pdf.py` | `assert` is removed under `-O` | Rewritten as `elif bullet_match is not None` without `assert` |
| B406 (xml.sax escape) | `backend/services/guide_pdf.py` | It does not parse XML | `escape()` here escapes user text before inserting it into reportlab rather than parsing untrusted XML — excluded in `[tool.bandit].skips` with a rationale |
| B105 (hard-coded password) | `backend/core/config.py` | A dev placeholder value | In production the validator rejects the default key and keys shorter than 32 characters — excluded in `skips` with a rationale |

Result: no active SAST findings. The remaining exclusions are documented in `pyproject.toml` together with the reasons, not "silently muted".

## 2. SCA — Python (`pip-audit`)

```
python -m pip_audit --progress-spinner off
```

### Before

124 known vulnerabilities in 7 packages, including `cryptography` (44.0.0), `pypdf` (5.1.0), `python-jose` (3.3.0), `python-multipart` (0.0.20), `starlette` (0.41.3).

### After

```
Found 2 known vulnerabilities in 1 package
ecdsa  0.19.2  PYSEC-2026-1325
```

### What was updated

| Package | Before | After | Reason |
|---|---|---|---|
| `fastapi` | 0.115.6 | 0.141.1 | pulls in the fixed Starlette |
| `starlette` | 0.41.3 | 1.7.0 (through FastAPI) | path traversal and others |
| `prometheus-fastapi-instrumentator` | 7.0.0 | 8.1.0 | compatibility with the new Starlette (7.x failed on `_IncludedRouter`) |
| `python-jose[cryptography]` | 3.3.0 | 3.5.0 | algorithmic JOSE CVEs |
| `python-multipart` | 0.0.20 | 0.0.31 | ReDoS/DoS in the form parser |
| `cryptography` | 44.0.0 | 50.0.1 | the PYSEC-2026 series |
| `pypdf` | 5.1.0 | 6.19.0 | MRO/PDF parsing |
| `pytest` / `pytest-asyncio` | 8.3.4 / 0.25.0 | 9.1.1 / 1.4.0 | PYSEC-2026-1845 |

### Residual risk

`ecdsa 0.19.2` (PYSEC-2026-1325) has no fix — it is a transitive dependency of `python-jose`, used only when verifying tokens with EC keys. The system signs JWTs with **HS256** (`settings.algorithm`, `backend/auth/security.py`), so the `ecdsa` code path is never called. On a move to ES256/RS256 the package must be replaced with the `cryptography` implementation.

## 3. SCA — Frontend (`npm audit`)

### Before

6 vulnerabilities (1 critical, 1 high, 4 moderate): `jspdf` (critical, PDF injection, ReDoS, path traversal), `vite` (high, bypass of `server.fs.deny`), `react-router`/`react-router-dom` (moderate, open redirect), `dompurify`, `esbuild` (moderate).

### After

```
found 0 vulnerabilities
```

### What was updated

| Package | Before | After | Reason |
|---|---|---|---|
| `jspdf` | 2.5.2 | 4.2.1 | critical: PDF injection, ReDoS, path traversal |
| `vite` | 5.0.8 | 7.3.6 | high: bypass of `server.fs.deny`, path traversal |
| `@vitejs/plugin-react` | ^4.2.1 | ^5.2.0 | compatibility with Vite 7 |
| `react-router-dom` | 6.20.0 | 7.18.4 | open redirect, constructor injection |

`npm run build` and `npx tsc --noEmit` pass after the updates; the backend tests — 94 passed.

## 4. Reproducibility

Both checks run automatically:

```
# .github/workflows/ci.yml, job security
- pip-audit -r backend/requirements.txt
- npm audit --audit-level=high
```

The job is marked `continue-on-error: true`: new advisories are published daily and must not block the build, but the presence of vulnerabilities is visible in the CI log. Bandit is a candidate for a separate step once daily builds are introduced.